信息安全测评与风险评估

7.4.2 工控安全配置核查

授课教师：张玉



目录

CONTENTS

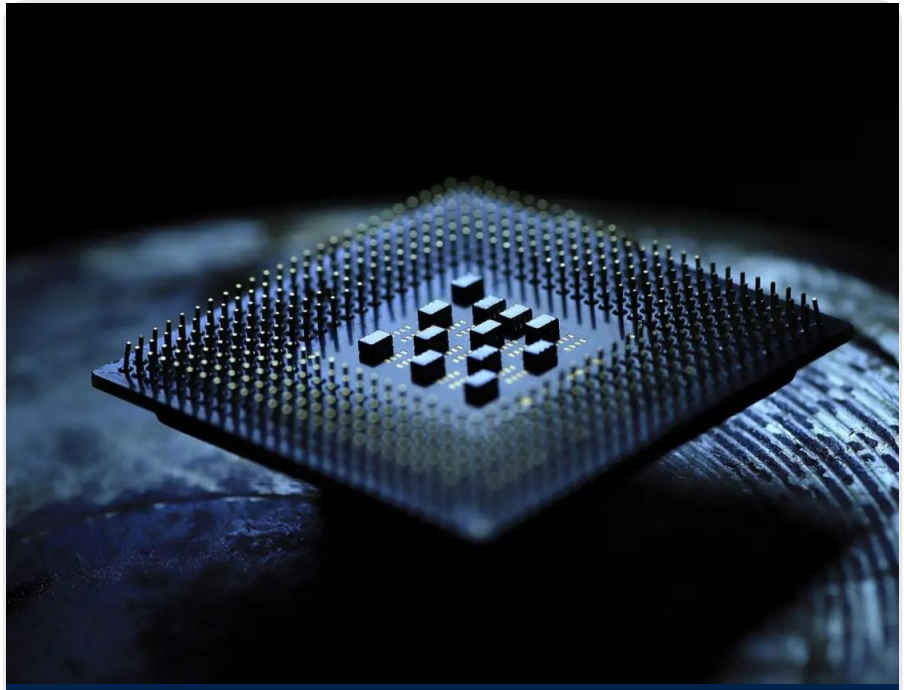
01 案例导入：圣诞夜大停电——点击

02 学习目标

03 工控安全配置核查——在等保标准中的定位

04 工控安全扩展要求——控制设备安全核心指标

案例导入：圣诞夜大停电——乌克兰电网攻击



结论：工控设备的安全配置是“最后一公里”——配置不当，再先进的架构也形同虚设。

案例素材

2015年12月23日，乌克兰约23万户家庭突然断电。攻击者提前半年潜伏：钓鱼邮件投毒、窃取远程运维账号，当晚逐台操作断路器，并同步发动[illegible]堵死客服电话。

- 远程运维通道管控缺失
- 账号权限未分离
- 关键操作无审计记录
- 备份与恢复演练不足

问题

Q： 一夜断电，源头是哪几项配置？

学习目标

通过本课学习，你将能够：

01 理解	工控安全扩展要求中“控制设备安全”的测评指标
02 掌握	工控设备安全配置核查的六个核心维度
03 能够	使用基本命令对工控设备进行安全配置核查
04 能够	规范填写《工业控制系统安全测评记录表》
05 具备	识别工控设备常见安全配置缺陷的能力

工控安全配置核查——在等保标准中的定位

GB/T 22239-2019 8.5.4 安全计算环境 → 控制设备安全

工控安全扩展要求——安全计算环境的五个子类：

本课重点：身份鉴别 + 访问控制 + 安全审计 + 控制设备基础安全

序号	子类	核心内容
1	身份鉴别	控制设备的用户身份标识与鉴别机制
2	访问控制	控制设备的权限管理与最小权限原则
3	安全审计	控制设备的操作日志与审计功能
4	控制设备安全（综合）	补丁更新、接口关闭、专用软件更新
5	恶意代码防范	控制设备的防病毒与白名单机制

工控安全扩展要求——控制设备安全核心指标

GB/T 22239 8.5.4.1 控制设备安全（第三级）

序号	检查项	标准要求	测评方法
1	身份鉴别	控制设备自身应实现身份鉴别	登录设备查看认证配置
2	访问控制	控制设备自身应实现访问控制	检查用户权限分配
3	安全审计	控制设备自身应实现安全审计	检查日志功能是否开启
4	补丁更新	经过充分测试评估后对控制设备进行补丁更新	检查补丁管理记录
5	接口管理	关闭或拆除软盘、光盘、USB、串行口、多余网口	现场检查设备接口
6	专用更新	应使用专用设备和专用软件对控制设备进行更新	检查更新工具和流程
7	上线检测	控制设备上线前应经过安全性检测	检查上线检测报告

工控设备身份鉴别核查

核查目标： 控制设备是否对登录用户进行身份标识和鉴别

等保要求解读	检查子项	具体要求	不合规示例

常用核查命令 以西门子PLC为例

操作	命令/方法
查看用户列表	通过TIA Portal → 项目属性 → 用户与角色
检查密码策略	查看设备组态 → 安全设置
检查远程管理方式	查看设备IP端口：22(SSH)是否开放，23(Telnet)是否关闭

工控设备访问控制核查

核查目标：控制设备是否实现了基于最小权限原则的访问控制

等保要求解读：

检查子项	具体要求	不合规示例
用户角色划分	应区分管理员、操作员、只读用户等角色	所有用户拥有相同权限
最小权限原则	每个用户仅授予完成工作所需的最小权限	操作员拥有管理员权限
权限分离	工程投运与在线修改权限应有效隔离	在线运行时允许程序修改

核查要点：

01 登录设备 →**查看用户角色配置**

02 检查管理员账户是否为**唯一超级用户**

03 验证操作员账户是否**仅具有运行/监控权限**

04 确认是否存在**匿名访问**或默认账户

工控设备安全审计核查

等保要求解读

核查目标： 控制设备是否具有日志记录和审计功能

检查子项	具体要求	不合规示例
审计功能开启	安全审计功能应处于开启状态	日志功能未启用
审计内容覆盖	应覆盖登录、注销、参数修改、程序下载等	仅记录部分操作
审计记录要素	应包含日期、时间、用户、事件类型、结果等	记录信息不完整
审计记录保护	审计记录应受保护，避免删除或篡改	普通用户可删除日志
日志保存期限	应定期备份，保存不少于6个月	日志保存不足6个月

核查命令参考（通用）

操作	方法
检查审计功能	查看设备系统设置审计/日志配置
查看日志记录	导出日志文件，检查完整性
验证日志保护	尝试以普通用户身份删除日志

工控设备安全配置核查——实操六步法

工控设备配置核查的标准操作流程：

01 准备

获取设备清单、网络拓扑、管理权限

要点：确保已获得授权

→

02 信息收集

记录设备型号、固件版本、开放端口

要点：sh version/interface

→

03 身份鉴别核查

检查用户账户、密码策略、认证方式

要点：重点查默认/弱口令

↓

04 访问控制核查

检查用户角色、权限分配

要点：验证最小权限原则

→

05 审计核查

检查日志功能、审计策略

要点：确认审计覆盖范围

→

06 综合评估

汇总问题、填写记录表

要点：形成整改建议

控制设备基础安全——补丁与接口管理

核查目标： 控制设备是否及时更新补丁、关闭不必要的接口

（一）补丁更新核查

检查子项	具体要求	核查方法
补丁更新记录	是否有补丁更新计划与记录	查阅补丁管理文档

（二）接口管理核查

检查子项	具体要求	核查方法
物理接口	软盘驱动、光盘驱动、USB接口应关闭或拆除	现场检查设备

教师演示——工控设备配置核查（15分钟）

演示场景

在MobLab工控实验平台上，完整演示-



演示步骤

阶段	操作	演示要点
1. 连接设备	通过管理终端连接到工控设备	使用SSH/Console连接
2. 版本检查	show version	记录固件版本，判断是否过时

重点提示

- 工控设备的管理接口（HTTP、Telnet、SNMP）应严格限制访问来源
- 默认账户和默认密码是最常见的安全漏洞
- 如受条件限制控制设备无法实现安全要求，应由上位控制或管理设备实现同等功能

实践任务1——工控设备安全配置核查（20分钟）

素材1：实践任务——《工业控制系统

素材2：工控设备安全配置核查清单

任务名称	工控设备安全配置核查实操
任务环境	MobLab工控实验平台（模拟西门子PLC）
核查清单	① 身份鉴别检查（用户列表、密码策略、远程管理方式） ② 访问控制检查（用户角色、权限分配） ③ 安全审计检查（审计功能、日志记录） ④ 接口检查（物理接口、网络端口） ⑤ 补丁管理检查（补丁更新记录）
任务产出	完成《工业控制系统安全测评记录表》（见素材1）
时间安排	约20分钟

实践任务1——核查要点与常见问题

常见问题速查表

问题类型	常见表现	等保判定	整改建议
默认账户未修改	使用admin/admin、root/root等	✗ 不符合	删除默认账户或修改口令
弱口令	密码长度<8、无复杂度要求	✗ 不符合	启用复杂度策略
使用Telnet管理	远程管理采用明文传输	✗ 不符合	改用SSH

– 实践任务2——安全配置缺陷分析与整改建议（10分钟）

任务名称	工控设备安全缺陷分析与整改建议
任务场景	教师提供一份“工控设备配置核查报告”（脱敏），包含发现的安全问题
任务内容	① 分析每个问题的风险等级 ② 判断对应的等保不符合项 ③ 提出具体的整改建议
时间安排	约10分钟



素材4：工控安全配置缺陷分析与整改

工控安全配置核查报告与等保标准对应关系

将核查发现与等保条款一一对应，是测评报告编制的核心能力。

核查发现	对应等保条款	结论判定
PLC使用默认口令admin/admin	8.5.4.1a)身份鉴别	不符合
所有用户拥有管理员权限	8.5.4.1a)访问控制	不符合
未开启审计日志功能	8.5.4.1a)安全审计	不符合
补丁超过12个月未更新	8.5.4.1b)补丁更新	部分符合
设备USB接口未禁用	8.5.4.1c)接口管理	不符合
上位机实现访问控制	8.5.4.1a)由上上位控制设备实现	符合

工控安全配置核查常用命令速查（适用于西门子PLC）

核查项	命令/操作方法	说明
设备信息	showversion	查看固件版本
网络接口	showinterface	查看端口状态
用户列表	通过TIAPortal查看	检查账户配置
开放端口	端口扫描工具	检查22/23/80等端口
日志配置	设备系统设置	检查审计功能
SNMP配置	showsnmp	检查SNMP版本和社区串

工控安全配置核查报告示例（部分）

模拟报告节选：

序号	检查项	检查结果	合规性	风险描述	整改建议
1	身份鉴别	PLC使用默认账户admin，密码123456		攻击者可轻易获取控制权	立即修改密码，启用复杂度策略
2	访问控制	所有用户均具备管理员权限		无法实现权限分离	划分管理员/操作员/只读角色
3	安全审计	未开启审计日志		无法追溯操作行为	启用审计功能，配置日志策略
4	补丁管理	固件版本为3年前版本，无更新记录		可能存在已知漏洞	制定补丁更新计划并测试

思政融入——工控安全配置核查的职业责任



细致

- 每个配置项都可能影响生产安全
- 一次拉闸，就是23万户的黑暗
- 核查必须一丝不苟



担当

- 工控安全关乎企业效益与国计民生
- 电力、交通任一环节出问题影响深远
- 测评师是工业“生命线”守护者



合规

- 等保2.0扩展要求是国家意志体现
- 合规不是“纸上谈兵”是“实战要求”
- 每次核查都在为工业安全添砖加瓦

工控安全配置核查，查的是设备，守的是国家安全。

知识点回顾（5分钟）

工控安全配置核查

思维导图（本课核心知识）

1. **控制设备安全核心指标**
   - **身份鉴别：**唯一标识 + 复杂度口令 + 加密管理
   - **安全审计：**日志开启 + 完整记录 + 保存保护
   - **访问控制：**角色划分 + 最小权限 + 权限分离
   - **补丁/接口：**测试验证 + 禁用USB等多余端口
2. **核查六步法**

   准备 → 信息收集 → 身份鉴别 → 访问控制 → 审计核查 → 综合评估
3. **常见问题**

   默认口令、弱口令、Telnet、日志关闭、USB未禁用
4. **与等保标准的对应**

   每个核查发现都需要对应到具体的标准条款

课后作业

必做	完成《工业控制系统安全测评记录表》，提交至学习通平台
必做	完成活动7.4.2在线测试（选择题+判断题，共15题）
选做	查阅一种工控设备（如西门子S7-1200）的安全配置手册，总结关键配置项
预习	预习任务8“信息安全风险评估”相关内容

下节课预告

任务8：信息安全风险评估

预告内容

01 风险评估基本概念与GB/T 20984标准流程

02 资产识别与CIA三性赋值

03 威胁识别与脆弱性识别

04 风险计算方法（矩阵法/相乘法）
风险评估报告编制

课前准备

复习GB/T 20984标准框架

回顾之前项目的测评记录

课堂小结与答疑

三个核心知识点

① ① 断电不是设备故障，是配置疏忽铺成的路

② 工控安全配置核查六步法

③ ③ 每个核查项，背后都是千家万户的灯火

两个关键技能

① 能使用基本命令进行工控设备配置核查

② 能规范填写《工业控制系统安全测评记录表》

一个职业准则

- 配置核查查的是设备，守的是万家灯火

互动答疑：欢迎大家交流提问

感谢观看

